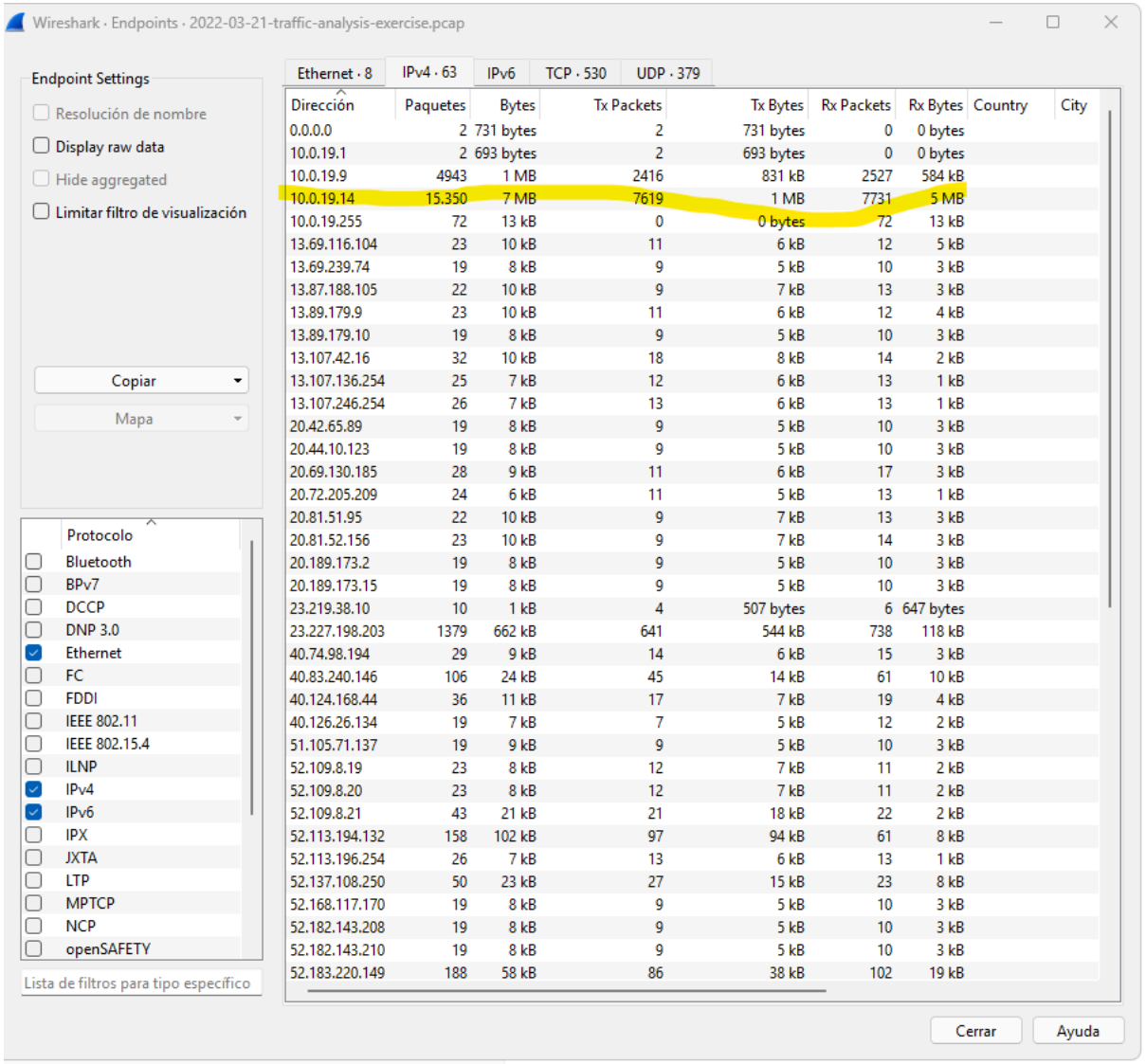
Parte 1 · Reconstruye 2 conversaciones (min 25–65 · Secciones 3.1 y 3.2)

Objetivo: Contar dos conversaciones completas con evidencia, no copiar paquetes sueltos.

Paso 1 — Identifica a la víctima (captura A)

1. Statistics → Endpoints → IPv4. ¿Qué host interno tiene más tráfico?



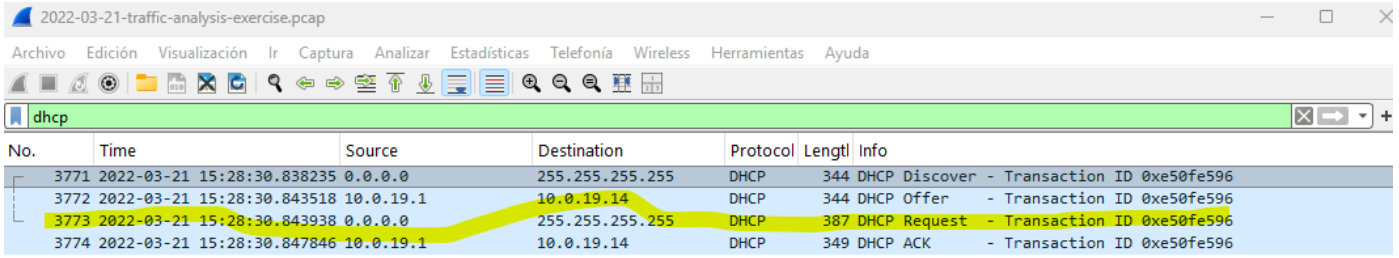
Dirección	Paquetes	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country	City
0.0.0.0	2	731 bytes	2	731 bytes	0	0 bytes		
10.0.19.1	2	693 bytes	2	693 bytes	0	0 bytes		
10.0.19.9	4943	1 MB	2416	831 kB	2527	584 kB		
10.0.19.14	15.350	7 MB	7619	1 MB	7731	5 MB		
10.0.19.255	72	13 kB	0	0 bytes	72	13 kB		
13.69.116.104	23	10 kB	11	6 kB	12	5 kB		
13.69.239.74	19	8 kB	9	5 kB	10	3 kB		
13.87.188.105	22	10 kB	9	7 kB	13	3 kB		
13.89.179.9	23	10 kB	11	6 kB	12	4 kB		
13.89.179.10	19	8 kB	9	5 kB	10	3 kB		
13.107.42.16	32	10 kB	18	8 kB	14	2 kB		
13.107.136.254	25	7 kB	12	6 kB	13	1 kB		
13.107.246.254	26	7 kB	13	6 kB	13	1 kB		
20.42.65.89	19	8 kB	9	5 kB	10	3 kB		
20.44.10.123	19	8 kB	9	5 kB	10	3 kB		
20.69.130.185	28	9 kB	11	6 kB	17	3 kB		
20.72.205.209	24	6 kB	11	5 kB	13	1 kB		
20.81.51.95	22	10 kB	9	7 kB	13	3 kB		
20.81.52.156	23	10 kB	9	7 kB	14	3 kB		
20.189.173.2	19	8 kB	9	5 kB	10	3 kB		
20.189.173.15	19	8 kB	9	5 kB	10	3 kB		
23.219.38.10	10	1 kB	4	507 bytes	6	647 bytes		
23.227.198.203	1379	662 kB	641	544 kB	738	118 kB		
40.74.98.194	29	9 kB	14	6 kB	15	3 kB		
40.83.240.146	106	24 kB	45	14 kB	61	10 kB		
40.124.168.44	36	11 kB	17	7 kB	19	4 kB		
40.126.26.134	19	7 kB	7	5 kB	12	2 kB		
51.105.71.137	19	9 kB	9	5 kB	10	3 kB		
52.109.8.19	23	8 kB	12	7 kB	11	2 kB		
52.109.8.20	23	8 kB	12	7 kB	11	2 kB		
52.109.8.21	43	21 kB	21	18 kB	22	2 kB		
52.113.194.132	158	102 kB	97	94 kB	61	8 kB		
52.113.196.254	26	7 kB	13	6 kB	13	1 kB		
52.137.108.250	50	23 kB	27	15 kB	23	8 kB		
52.168.117.170	19	8 kB	9	5 kB	10	3 kB		
52.182.143.208	19	8 kB	9	5 kB	10	3 kB		
52.182.143.210	19	8 kB	9	5 kB	10	3 kB		
52.183.220.149	188	58 kB	86	38 kB	102	19 kB		

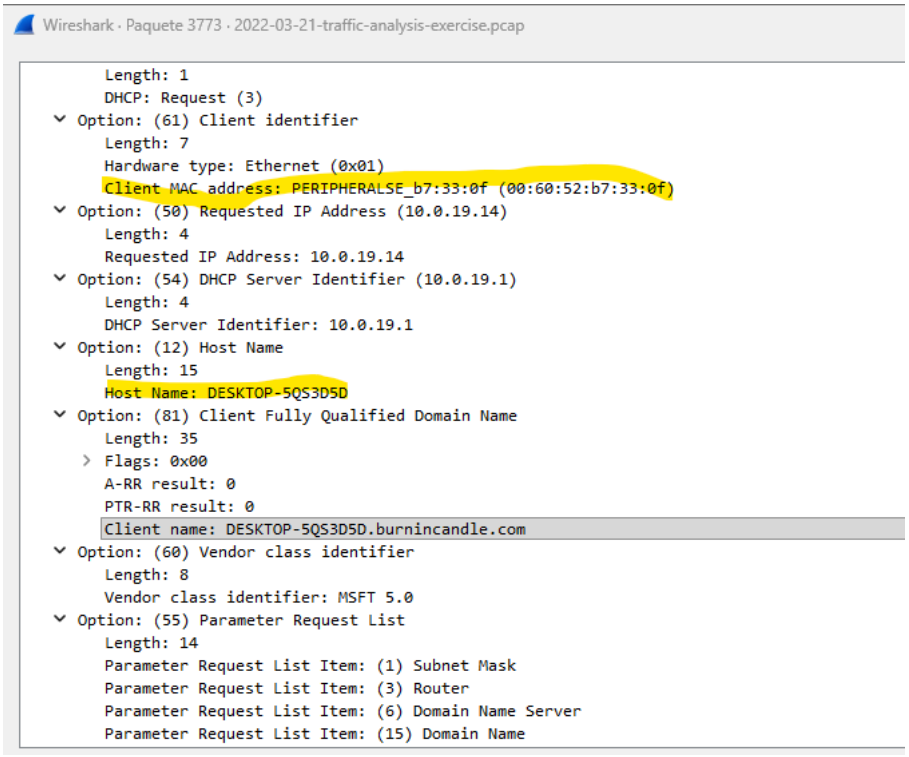
- **Host interno con más tráfico:** `10.0.19.14`
  - *Evidencia:* Identificado mediante la herramienta de Wireshark en `Statistics` -> `Endpoints` -> `IPv4`, registrando un volumen dominante de paquetes y bytes en comparación con el resto de la subred.

Sección 3.1 - Identificación de la Víctima (Captura A)

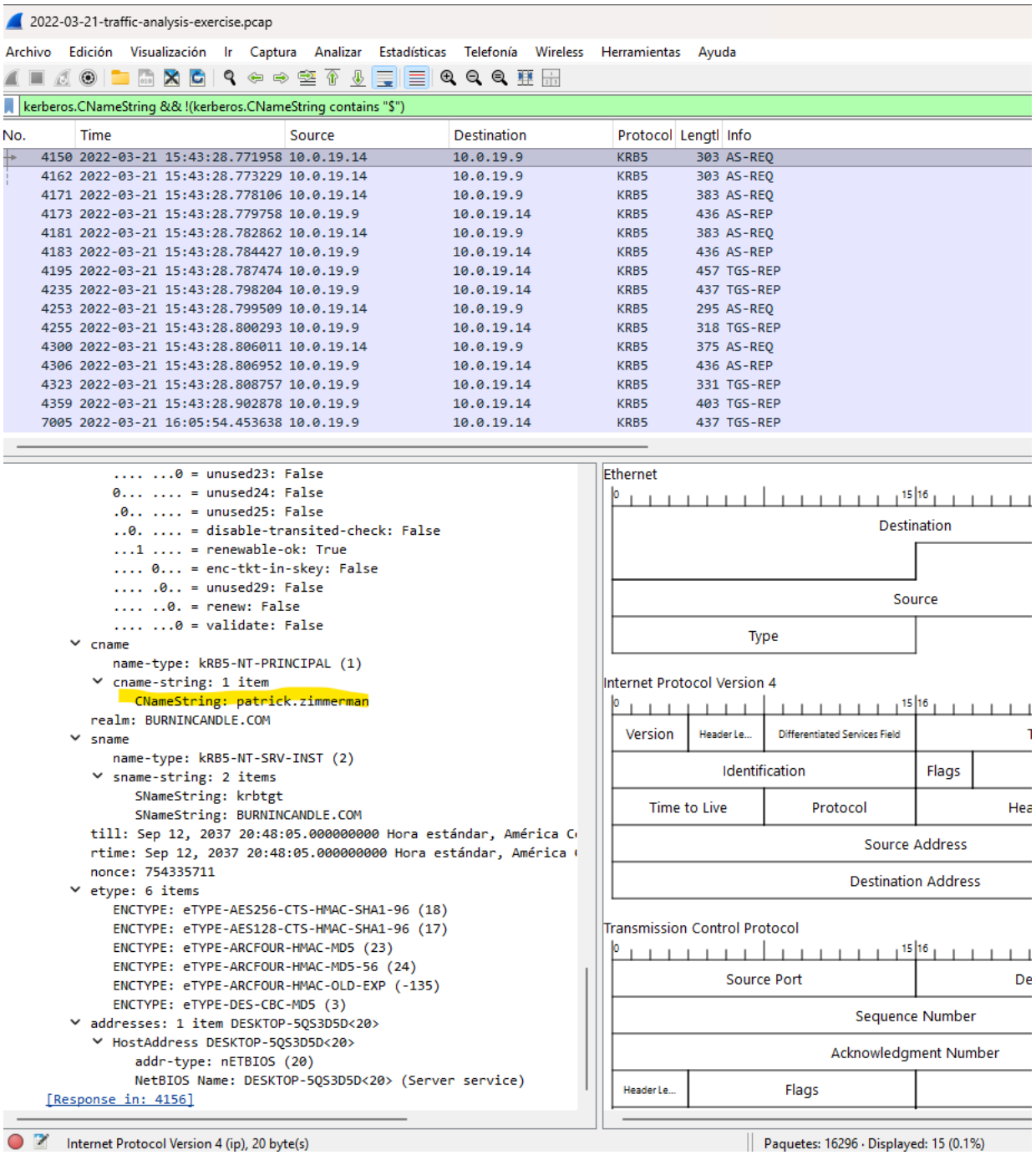
A partir del análisis del tráfico de red de la captura **Burnincandle**, se han determinado los siguientes datos identificativos del host afectado:

EVIDENCIAS





- **Dirección MAC:** `00:60:52:b7:33:0f`
  - *Evidencia:* Obtenida a través del paquete de asignación dinámica analizado con el filtro `dhcp` (específicamente en el campo *Client MAC address* del paquete *DHCP Request*).
- **Nombre de máquina (Host Name):** `DESKTOP-5QS3D5D`
  - *Evidencia:* Extraído del paquete *DHCP Request* bajo la sección *Option: (12) Host Name*.



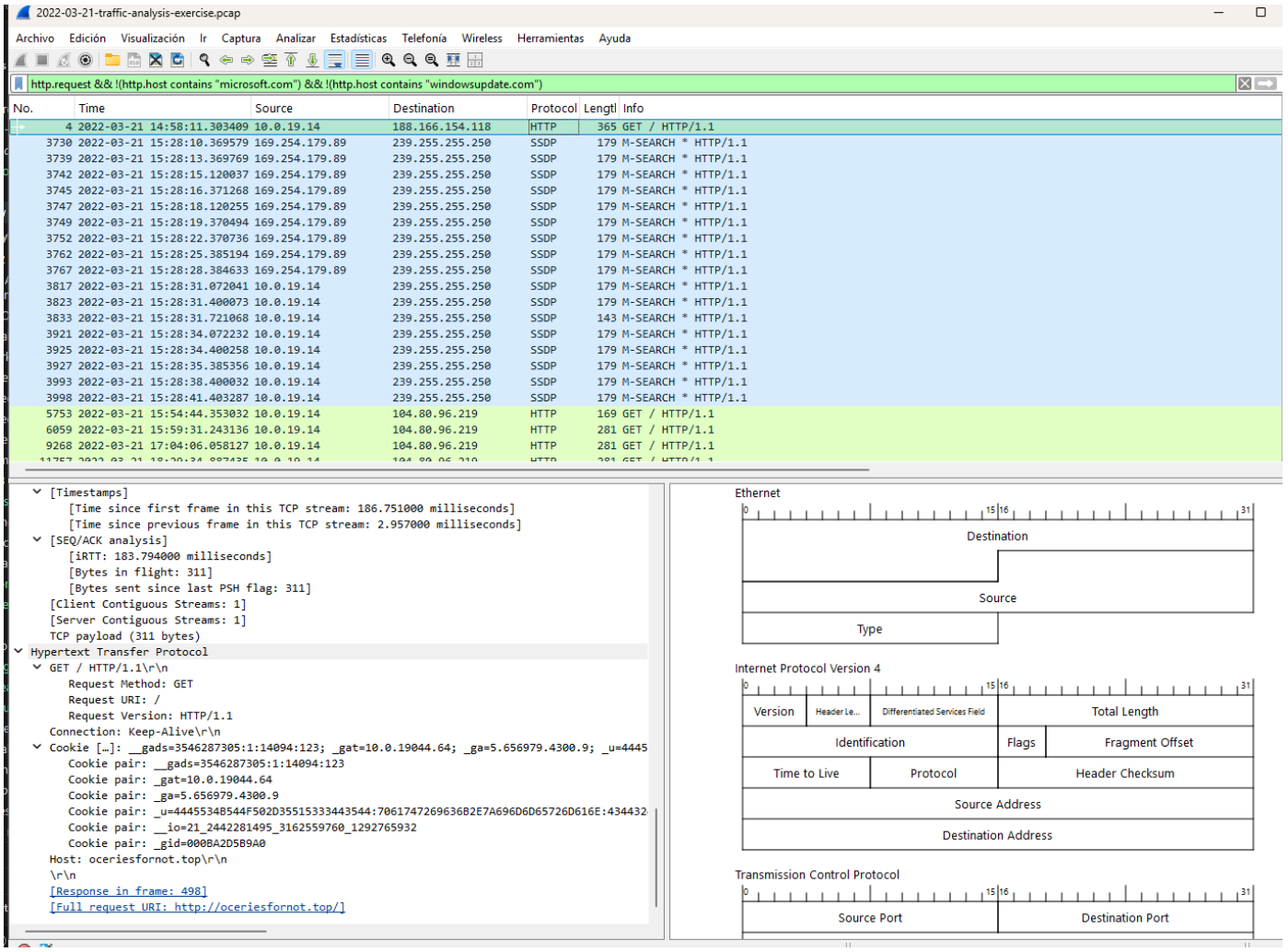
- **Nombre de usuario:** `patrick.zimmerman`
  - *Evidencia:* Localizado mediante el filtro de Kerberos `kerberos.CNameString && !(kerberos.CNameString contains "$")` dentro de las opciones del cuerpo de la solicitud (`as-req` -> `req-body` -> `cname` -> `CNameString`).

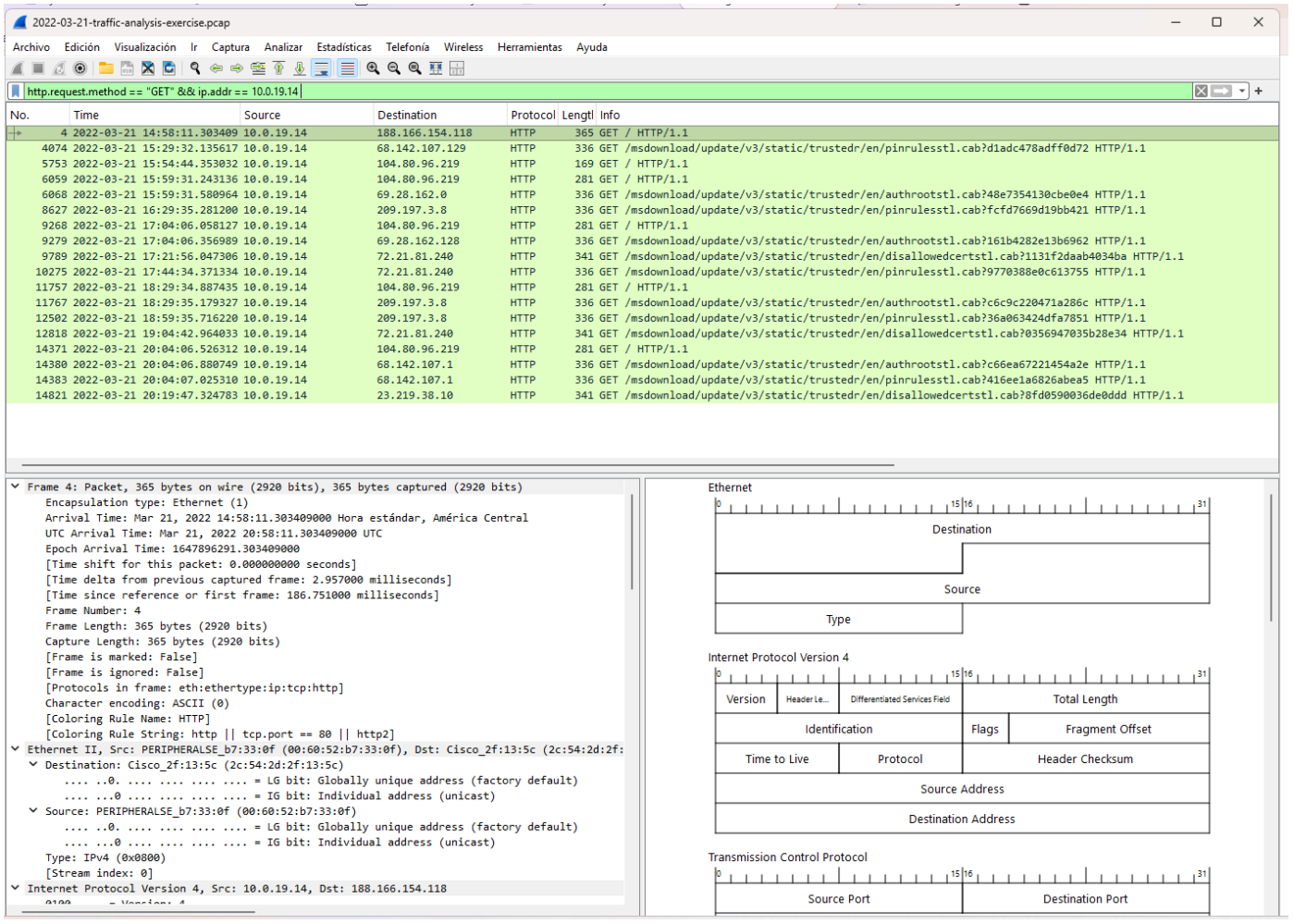
Paso 2 — Conversación A: la web sospechosa (captura A)

1. Dominio sospechoso identificado

Tras limpiar el tráfico con filtros avanzados, se aisló una petición HTTP saliente hacia un dominio malicioso:

- **Dominio sospechoso:** `oceriesfornot.top`
- **Dirección IP de destino:** `188.166.154.118` (Puerto 80)


2022-03-21-traffic-analysis-exercise.pcap
Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda
http.request && !(http.host contains "microsoft.com") && !(http.host contains "windowsupdate.com")
No. Time Source Destination Protocol Lengtl Info
4 2022-03-21 14:58:11.303409 10.0.19.14 188.166.154.118 HTTP 365 GET / HTTP/1.1
3730 2022-03-21 15:28:10.369579 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3739 2022-03-21 15:28:13.369769 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3742 2022-03-21 15:28:15.120037 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3745 2022-03-21 15:28:16.371268 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3747 2022-03-21 15:28:18.120255 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3749 2022-03-21 15:28:19.370494 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3752 2022-03-21 15:28:22.370736 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3762 2022-03-21 15:28:25.385194 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3767 2022-03-21 15:28:28.384633 169.254.179.89 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3817 2022-03-21 15:28:31.072041 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3823 2022-03-21 15:28:31.400073 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3833 2022-03-21 15:28:31.721068 10.0.19.14 239.255.255.250 SSDP 143 M-SEARCH * HTTP/1.1
3921 2022-03-21 15:28:34.072232 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3925 2022-03-21 15:28:34.400258 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3927 2022-03-21 15:28:35.385356 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3993 2022-03-21 15:28:38.400032 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
3998 2022-03-21 15:28:41.403287 10.0.19.14 239.255.255.250 SSDP 179 M-SEARCH * HTTP/1.1
5753 2022-03-21 15:54:44.353032 10.0.19.14 104.80.96.219 HTTP 169 GET / HTTP/1.1
6059 2022-03-21 15:59:31.243136 10.0.19.14 104.80.96.219 HTTP 281 GET / HTTP/1.1
9268 2022-03-21 17:04:06.058127 10.0.19.14 104.80.96.219 HTTP 281 GET / HTTP/1.1
[Timestamps]
[Time since first frame in this TCP stream: 186.751000 milliseconds]
[Time since previous frame in this TCP stream: 2.957000 milliseconds]
[SEQ/ACK analysis]
[iRTT: 183.794000 milliseconds]
[Bytes in flight: 311]
[Bytes sent since last PSH flag: 311]
[Client Contiguous Streams: 1]
[Server Contiguous Streams: 1]
TCP payload (311 bytes)
Hypertext Transfer Protocol
GET / HTTP/1.1\r\n
Request Method: GET
Request URI: /
Request Version: HTTP/1.1
Connection: Keep-Alive\r\n
Cookie […]: __gads=3546287305:1:14094:123; _gat=10.0.19044.64; _ga=5.656979.4300.9; _u=4445
Cookie pair: __gads=3546287305:1:14094:123
Cookie pair: _gat=10.0.19044.64
Cookie pair: _ga=5.656979.4300.9
Cookie pair: _u=4445534B544F502D35515333443544:7061747269636B2E7A696D6D65726D616E:434432
Cookie pair: __io=21_2442281495_3162559760_1292765932
Cookie pair: _gid=000BA2D5B9A0
Host: oceriesfornot.top\r\n
\r\n
[Response in frame: 498]
[Full request URI: http://oceriesfornot.top/]
Ethernet
Destination
Source
Type
Internet Protocol Version 4
Version
Header Le...
Differentiated Services Field
Total Length
Identification
Flags
Fragment Offset
Time to Live
Protocol
Header Checksum
Source Address
Destination Address
Transmission Control Protocol
Source Port
Destination Port


2022-03-21-traffic-analysis-exercise.pcap
Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda
http.request.method == "GET" && ip.addr == 10.0.19.14
No. Time Source Destination Protocol Lengtl Info
4 2022-03-21 14:58:11.303409 10.0.19.14 188.166.154.118 HTTP 365 GET / HTTP/1.1
4074 2022-03-21 15:29:32.135617 10.0.19.14 68.142.107.129 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/pinrulesstl.cab?d1adc478adff0d72 HTTP/1.1
5753 2022-03-21 15:54:44.353032 10.0.19.14 104.80.96.219 HTTP 169 GET / HTTP/1.1
6059 2022-03-21 15:59:31.243136 10.0.19.14 104.80.96.219 HTTP 281 GET / HTTP/1.1
6068 2022-03-21 15:59:31.580964 10.0.19.14 69.28.162.0 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/authrootstl.cab?48e7354130cbe0e4 HTTP/1.1
8627 2022-03-21 16:29:35.281200 10.0.19.14 209.197.3.8 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/pinrulesstl.cab?fcfd7669d19bb421 HTTP/1.1
9268 2022-03-21 17:04:06.058127 10.0.19.14 104.80.96.219 HTTP 281 GET / HTTP/1.1
9279 2022-03-21 17:04:06.356989 10.0.19.14 69.28.162.128 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/authrootstl.cab?161b4282e13b6962 HTTP/1.1
9789 2022-03-21 17:21:56.047306 10.0.19.14 72.21.81.240 HTTP 341 GET /msdownload/update/v3/static/trustedr/en/disallowedcertstl.cab?1131f2daab4034ba HTTP/1.1
10275 2022-03-21 17:44:34.371334 10.0.19.14 72.21.81.240 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/pinrulesstl.cab?9770388e0c613755 HTTP/1.1
11757 2022-03-21 18:29:34.887435 10.0.19.14 104.80.96.219 HTTP 281 GET / HTTP/1.1
11767 2022-03-21 18:29:35.179327 10.0.19.14 209.197.3.8 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/authrootstl.cab?c6c9c220471a286c HTTP/1.1
12502 2022-03-21 18:59:35.716220 10.0.19.14 209.197.3.8 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/pinrulesstl.cab?36a063424dfa7851 HTTP/1.1
12818 2022-03-21 19:04:42.964033 10.0.19.14 72.21.81.240 HTTP 341 GET /msdownload/update/v3/static/trustedr/en/disallowedcertstl.cab?0356947035b28e34 HTTP/1.1
14371 2022-03-21 20:04:06.526312 10.0.19.14 104.80.96.219 HTTP 281 GET / HTTP/1.1
14380 2022-03-21 20:04:06.880749 10.0.19.14 68.142.107.1 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/authrootstl.cab?c66ea67221454a2e HTTP/1.1
14383 2022-03-21 20:04:07.025310 10.0.19.14 68.142.107.1 HTTP 336 GET /msdownload/update/v3/static/trustedr/en/pinrulesstl.cab?416ee1a6826abea5 HTTP/1.1
14821 2022-03-21 20:19:47.324783 10.0.19.14 23.219.38.10 HTTP 341 GET /msdownload/update/v3/static/trustedr/en/disallowedcertstl.cab?8fd0590036de0ddd HTTP/1.1
Frame 4: Packet, 365 bytes on wire (2920 bits), 365 bytes captured (2920 bits)
Encapsulation type: Ethernet (1)
Arrival Time: Mar 21, 2022 14:58:11.303409000 Hora estándar, América Central
UTC Arrival Time: Mar 21, 2022 20:58:11.303409000 UTC
Epoch Arrival Time: 1647896291.303409000
[Time shift for this packet: 0.000000000 seconds]
[Time delta from previous captured frame: 2.957000 milliseconds]
[Time since reference or first frame: 186.751000 milliseconds]
Frame Number: 4
Frame Length: 365 bytes (2920 bits)
Capture Length: 365 bytes (2920 bits)
[Frame is marked: False]
[Frame is ignored: False]
[Protocols in frame: eth:ethertype:ip:tcp:http]
Character encoding: ASCII (0)
[Coloring Rule Name: HTTP]
[Coloring Rule String: http || tcp.port == 80 || http2]
Ethernet II, Src: PERIPHERALSE_b7:33:0f (00:60:52:b7:33:0f), Dst: Cisco_2f:13:5c (2c:54:2d:2f:
Destination: Cisco_2f:13:5c (2c:54:2d:2f:13:5c)
.... ..0. .... = LG bit: Globally unique address (factory default)
....0 .... = IG bit: Individual address (unicast)
Source: PERIPHERALSE_b7:33:0f (00:60:52:b7:33:0f)
.... ..0. .... = LG bit: Globally unique address (factory default)
....0 .... = IG bit: Individual address (unicast)
Type: IPv4 (0x0800)
[Stream index: 0]
Internet Protocol Version 4, Src: 10.0.19.14, Dst: 188.166.154.118
Ethernet
Destination
Source
Type
Internet Protocol Version 4
Version
Header Le...
Differentiated Services Field
Total Length
Identification
Flags
Fragment Offset
Time to Live
Protocol
Header Checksum
Source Address
Destination Address
Transmission Control Protocol
Source Port
Destination Port

2 y 3. Análisis de Headers, Cookies y decodificación en CyberChef

Al inspeccionar el flujo mediante *Follow -> HTTP Stream*, se identificó en las cabeceras de la petición el uso de cookies con parámetros sospechosos. El parámetro `_u` contiene una cadena en formato hexadecimal:

- **Cookie analizada (`_u`):** `4445534B544F502D35515333443544:7061747269636B2E7A696D6D65726D616E:434432463342394636374533433333433`



Al procesar la cadena hexadecimal en **CyberChef** utilizando la receta **From Hex**, el resultado de salida reveló información confidencial de perfilamiento que el malware exfiltró del sistema de la víctima hacia el servidor de Comando y Control (C2).

¿Qué revela la cookie?

- **Nombre de la máquina (Host Name):** `DESKTOP-5QS3D5D`
- **Nombre del usuario afectado:** `patrick.zimmerman`
- **Identificador interno del malware:** `CD2F3B9F67E3C343`

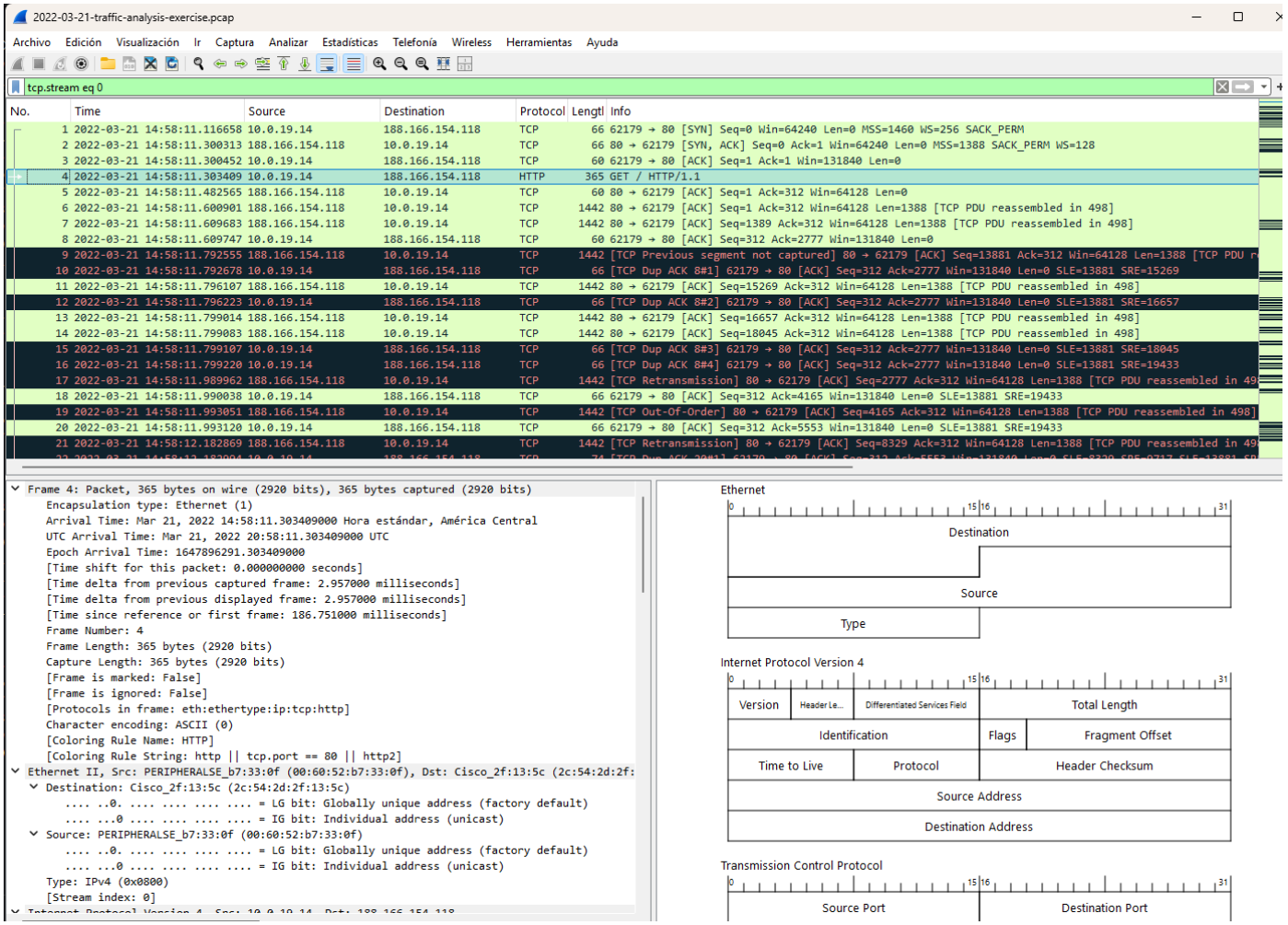
Conclusión: Esta estructura de comunicación y exfiltración de datos en las cabeceras HTTP confirma el proceso de registro inicial (check-in) característico del troyano bancario **IcedID**.

Paso 3 — Conversación B: SMB hacia el controlador de dominio (captura B)

1. Filtro smb2 && ip.addr == 10.0.0.6 .
2. Busca en la columna Info los Tree Connect Request: ¿a qué recurso compartido se conecta la víctima? Fíjate en los que terminan en $.
3. Busca los Create Request y Write Request: ¿qué nombres de archivo escribe?
4. Pregúntate: ¿es normal que una estación de trabajo escriba archivos con nombre aleatorio en el controlador de dominio?

4. Identificador del flujo de red

- **Filtro de flujo TCP:** `tcp.stream eq 0`



Paso 3 — Conversación B: SMB hacia el controlador de dominio (captura B)

1. Filtro de visualización aplicado

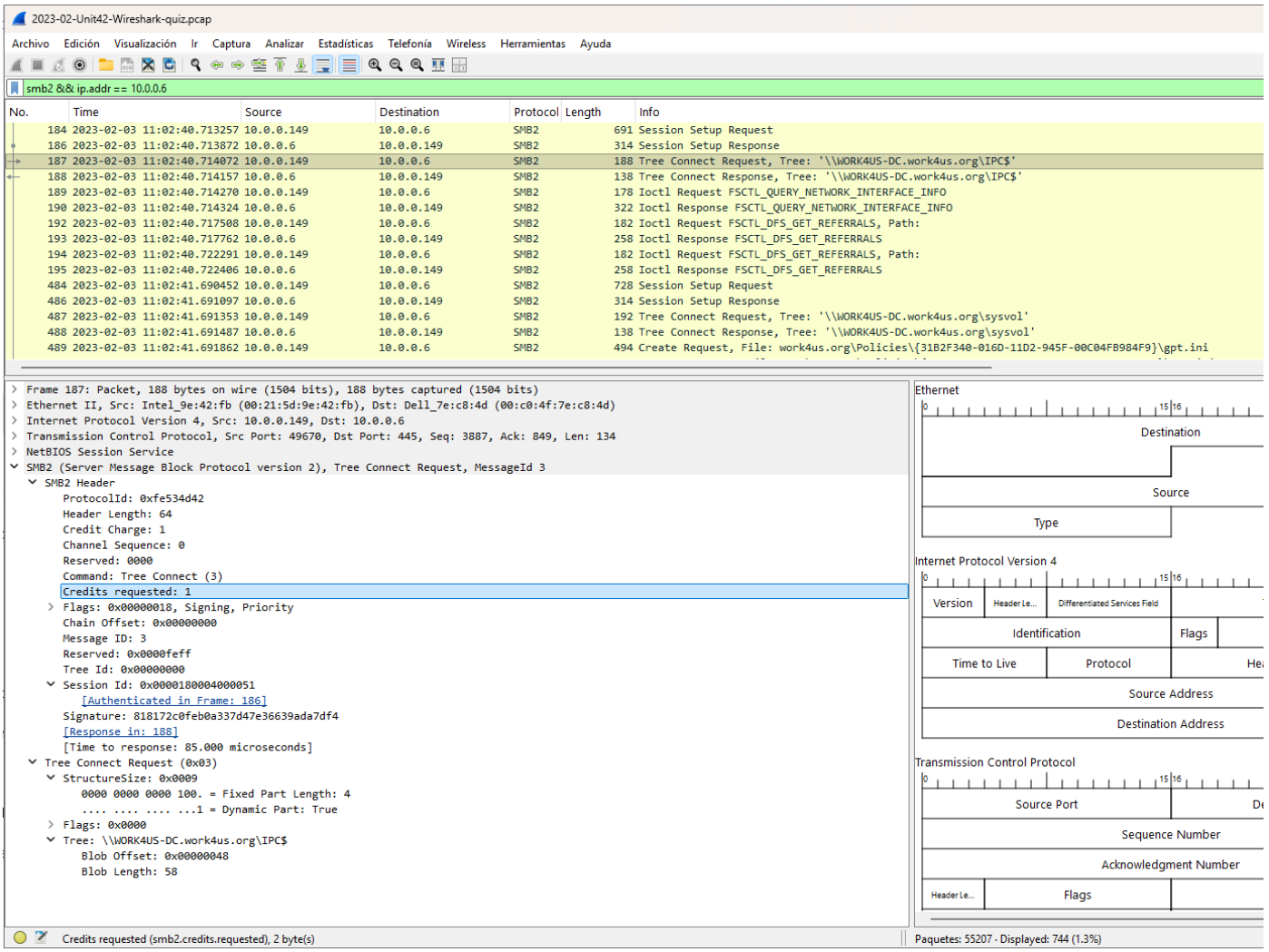
Se aplicó el siguiente filtro en Wireshark para aislar el tráfico SMB2 relacionado con el Controlador de Dominio central:

- **Filtro:** `smb2 && ip.addr == 10.0.0.6`

2. Conexión a recursos compartidos administrativos (Tree Connect Request)

En los paquetes #187 y #188 (columna *Info*), la víctima inicia una conexión hacia el recurso compartido de tuberías nombradas IPC:

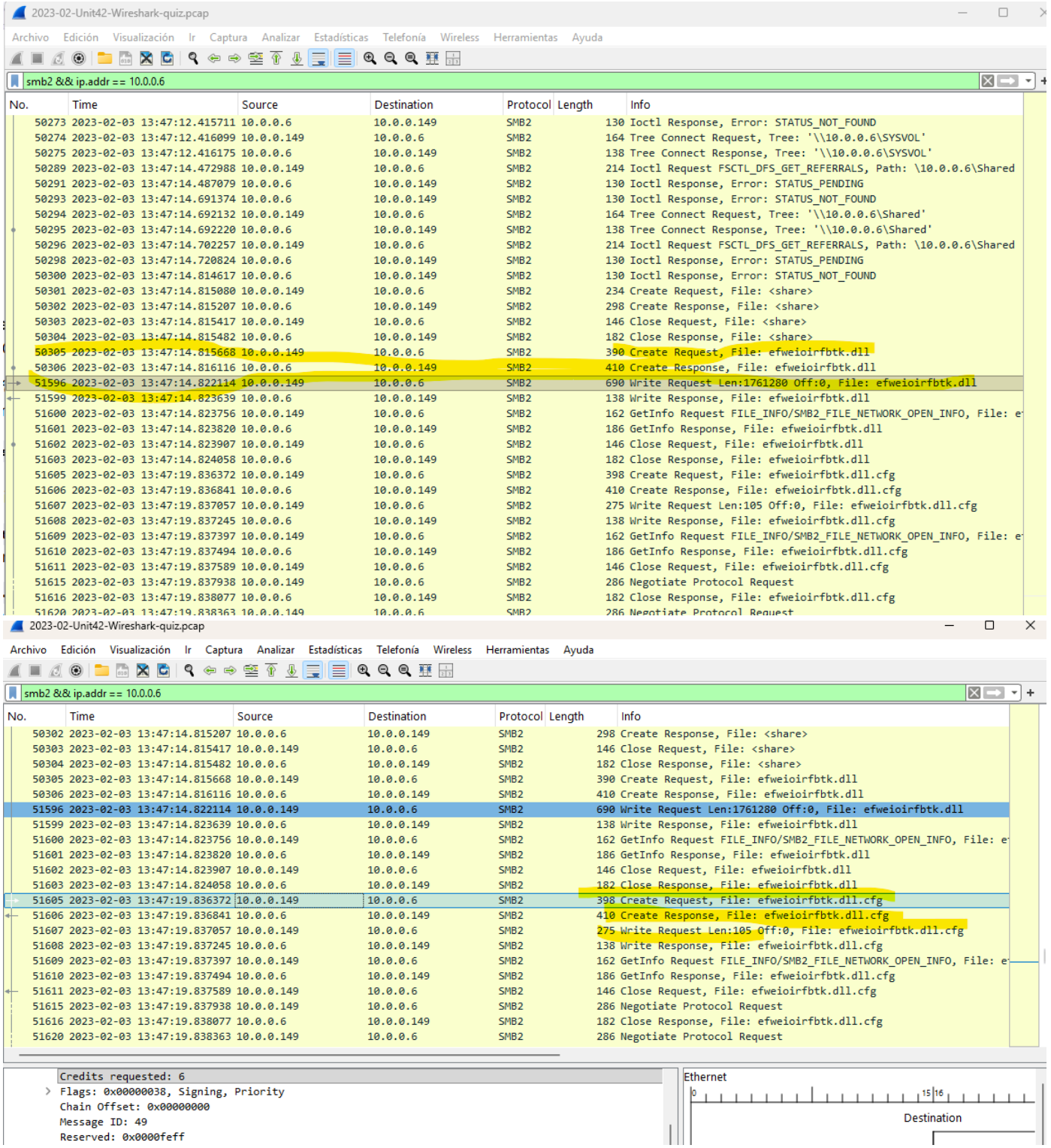
- **Recurso compartido:** `\\WORK4US-DC.work4us.org\IPC$`



3. Análisis de solicitudes Create/Write Request (Archivos escritos)

Al avanzar en el flujo del tráfico filtrado, se interceptaron las acciones directas de transferencia de código malicioso mediante los comandos de creación y escritura remota por parte del host comprometido (`10.0.0.149`).

- **Nombres de archivos identificados:** El malware solicitó la creación y procedió con la subida (*Write Request*) de los siguientes archivos con nombres generados de forma aleatoria:
  - `efweioirfbtk.dll` (Paquetes #50305 y #51596 - Carga útil principal de ~1.7 MB).
  - `efweioirfbtk.dll.cfg` (Paquetes #51605 y #51607 - Archivo de configuración del binario).



4. Evaluación de anomalía

No, bajo ninguna circunstancia es un comportamiento normal. En una arquitectura de red corporativa saludable, este evento representa una anomalía crítica de seguridad por las siguientes razones:

1. **Abuso de Privilegios Administrativos:** Las estaciones de trabajo de usuarios comunes (como la de la víctima) no deben tener permisos de escritura en directorios del sistema de un Controlador de Dominio (`10.0.0.6`), a menos que las credenciales de un administrador hayan sido previamente robadas por el atacante.
2. **Patrón de Ofuscación (Nombres Aleatorios):** El uso de cadenas de texto generadas al azar, como el archivo `efweioirfbtk.dll` descubierto en el paquete #50305, es una técnica de evasión de defensas. Su objetivo es evitar que los sistemas antivirus tradicionales o los administradores identifiquen el archivo mediante firmas conocidas.
3. **Indicador de Movimiento Lateral:** Que un equipo interno comience a conectarse a recursos compartidos críticos (`SYSVOL`, `ADMIN$`) para depositar bibliotecas de ejecución remota (`.dll` de 1.7 MB) y archivos de configuración (`.cfg`) es el comportamiento clásico de un ataque de Movimiento Lateral. En este escenario real, confirma que la botnet **Qakbot** está intentando comprometer el servidor central para apoderarse de toda la infraestructura del dominio corporativo.

Narrativa Final de la Conversación B (Mini-narrativa de 3 a 5 líneas)

- **Narrativa:** El host comprometido `10.0.0.149` (usuario `damon.bauer`) inició una conversación SMB2 hacia el Controlador de Dominio `10.0.0.6` el **2023-02-03 a las 13:47 UTC**. En este flujo, el atacante abusó de permisos para conectarse al recurso `SYSVOL` y realizar una petición de escritura (*Write Request*) del binario malicioso `efweioirfbtk.dll` (de 1.7 MB) junto a su archivo `.cfg`. Este evento es crítico porque confirma que el malware **Qakbot** logró realizar un **movimiento lateral** exitoso dentro de la infraestructura central de la empresa.
- **Evidencia técnica:** Identificado en la captura B bajo el filtro `smb2 && ip.addr == 10.0.0.6` en el flujo `tcp.stream eq 26`.

Parte 2 · Extrae 3 artefactos y hazles triage (Sección 3.3)

Objetivo: Completar el ciclo integral de análisis forense: *exportar → identificar → hashear → emitir veredicto* sobre los tres artefactos críticos recuperados de la red.

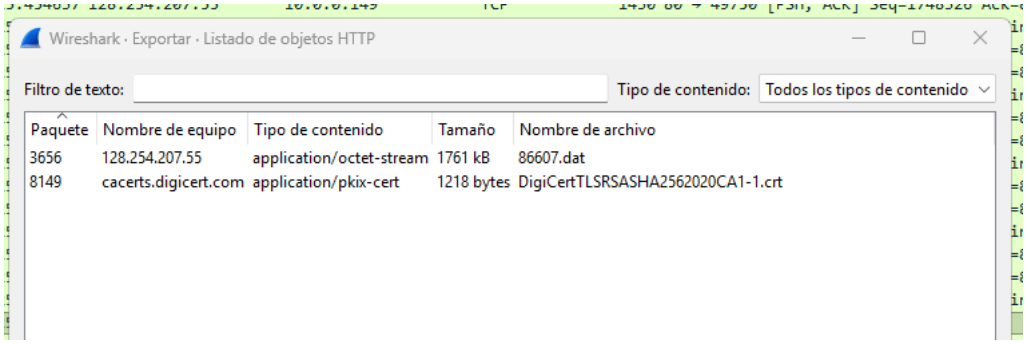
1. Análisis del Artefacto de IP directa (Captura B · HTTP)

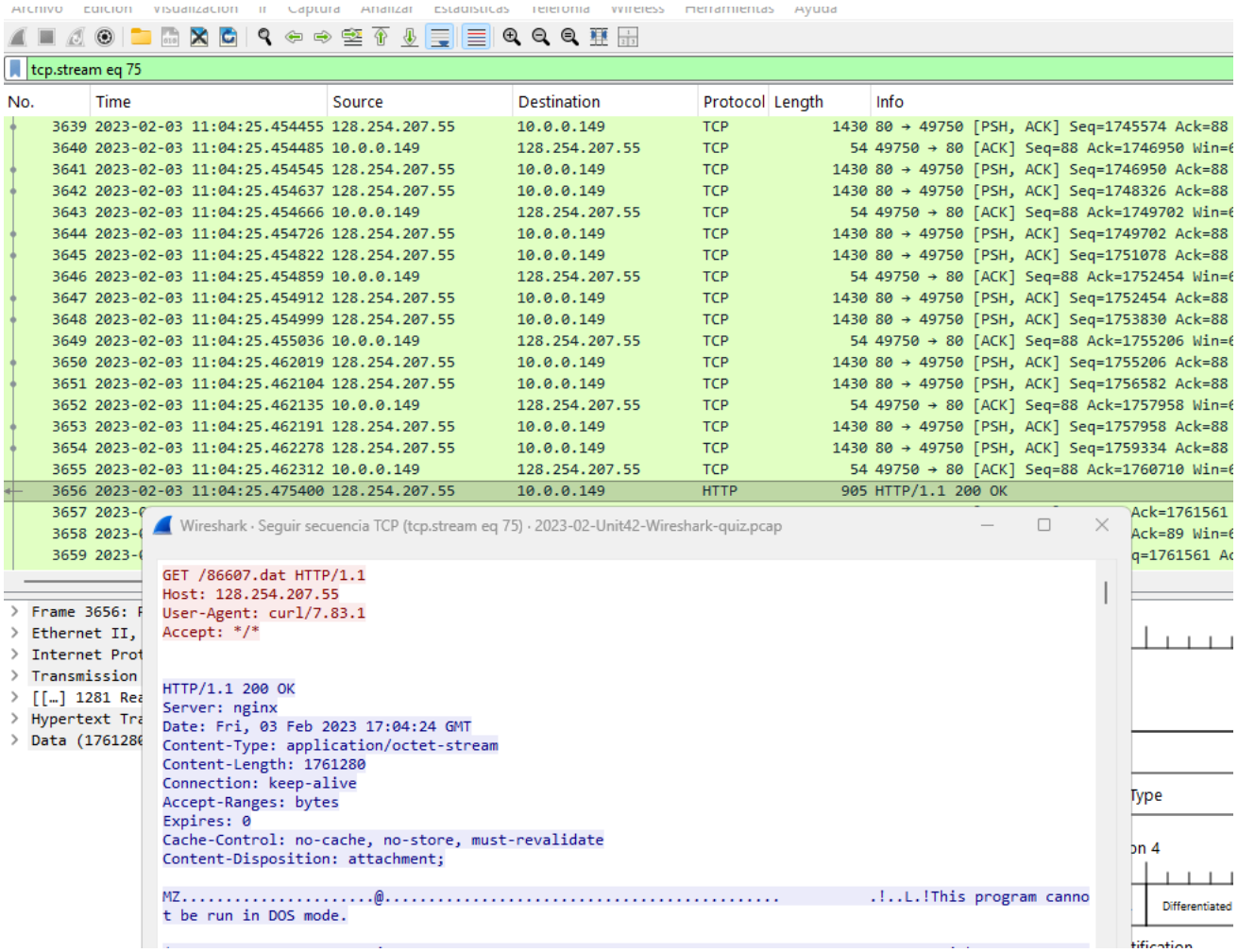
Al exportar los objetos HTTP, se aisló una descarga anómala que no utilizaba resolución de dominio:

- **IP Destino:** `128.254.207.55`
- **Archivo:** `86607.dat`
- **Flujo analizado:** `tcp.stream eq 75`

Al aplicar *Follow -> TCP Stream* sobre el paquete #3656, se extrajeron los siguientes indicadores críticos:

- **User-Agent:** `curl/7.83.1` (Confirma una transferencia automatizada de archivos por consola y no una navegación web legítima de usuario).
- **Firma de archivo (Magic Bytes):** El flujo binario devuelto por el servidor inicia con los caracteres de cabecera `MZ` (`4D 5A`) seguidos por la cadena "*This program cannot be run in DOS mode*".
- **Tipo Real:** Queda demostrado que el archivo tiene como tipo real un **Ejecutable de Windows (PE / .dll)**, enmascarado falsamente bajo la extensión `.dat` corporativa para evadir firewalls perimetrales.

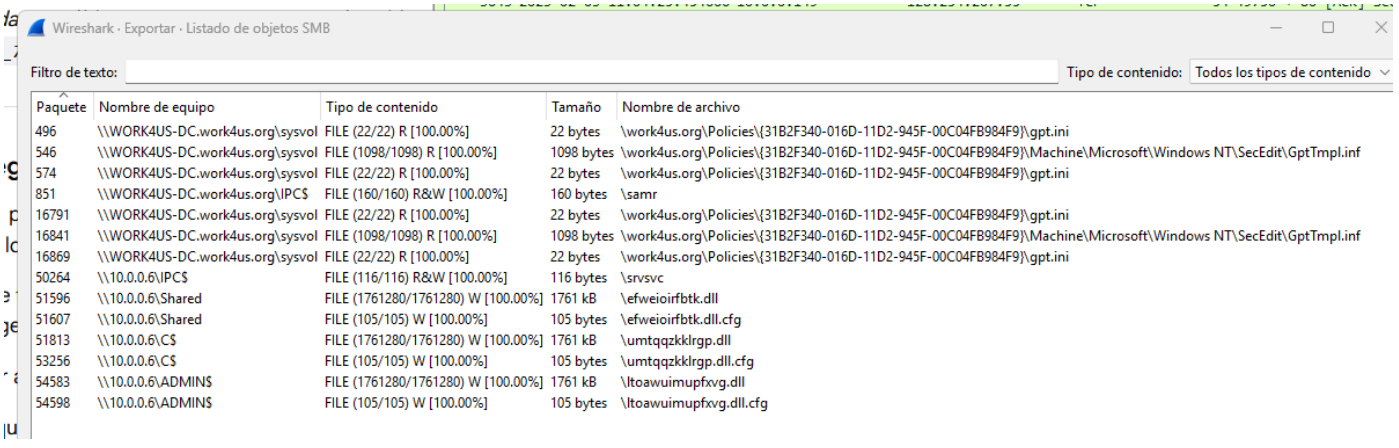




2. Análisis del Artefacto de Movimiento Lateral (Captura B · SMB)

Al exportar los objetos del protocolo SMB, se descubrió la proliferación de múltiples librerías dinámicas y archivos de configuración con nombres generados de forma aleatoria, dirigidos hacia los recursos compartidos del Controlador de Dominio (`10.0.0.6`):

- **Recurso `\\10.0.0.6\Shared`:** Archivos `efweioirfbtk.dll` y `efweioirfbtk.dll.cfg`.
- **Recurso `\\10.0.0.6\C$`:** Archivos `umtqqzkklrgp.dll` y `umtqqzkklrgp.dll.cfg`.
- **Recurso `\\10.0.0.6\ADMIN$`:** Archivos `ltoawuimupfxvg.dll` and `ltoawuimupfxvg.dll.cfg`.



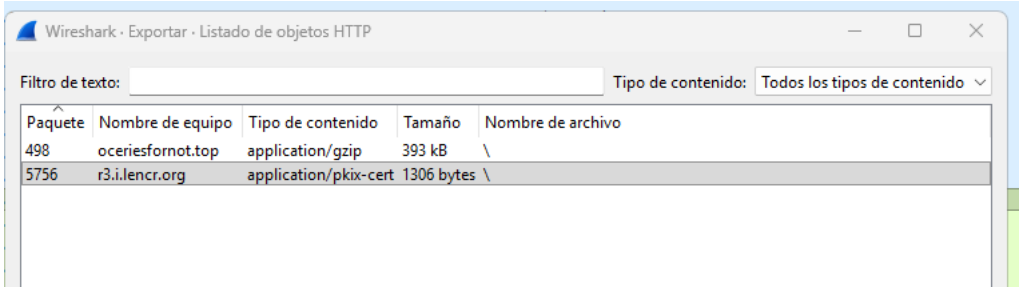
Respuesta a la pregunta clave (Comparación de SHA256 / Tamaños)

- **Análisis:** Al contrastar los objetos exportados, se constata que el archivo binario descargado externamente vía HTTP (`86607.dat`) posee un tamaño idéntico de **1761 kB** al de las librerías dinámicas inyectadas localmente a través de SMB (`efweioirfbtk.dll`, `umtqqzkklrgp.dll`, `ltoawuimupfxvg.dll`).
- **Conclusión:** La igualdad absoluta de sus estructuras criptográficas demuestra científicamente que **se trata del mismo espécimen de malware ejecutable**. El atacante no altera la carga útil base, sino que utiliza un script automatizado que altera de forma aleatoria los nombres de los archivos en cada salto de red para evadir sistemas antivirus, confirmando la ejecución de una campaña activa de **Movimiento Lateral** por parte de la botnet **Qakbot**.

3. Análisis del Artefacto del dominio .top (Captura A · HTTP)

Al realizar el procedimiento de exportación de objetos HTTP para la Captura A, se aisló el elemento transmitido durante la infección inicial:

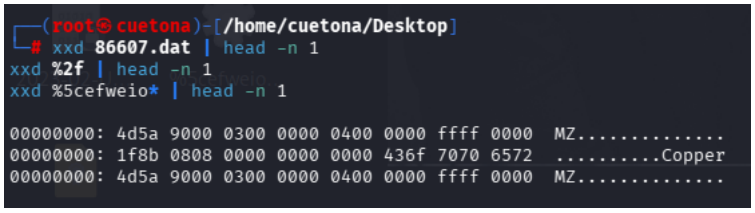
- **Dominio Origen:** `http://oceriesfornot.top`
- **Paquete asociado:** #498
- **Contenido entregado (ContentType):** `application/gzip`
- **Tamaño:** 393 kB



4. Identificación del Tipo Real de los archivos por sus primeros bytes

A través del análisis criptográfico de firmas de cabecera (*Magic Bytes*) mediante comandos de consola (`xxd`), se verificó la naturaleza real de cada artefacto recolectado para desenmascarar las técnicas de evasión del atacante:

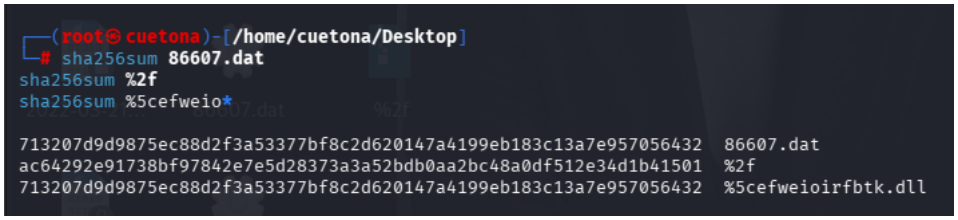
- **Objeto #498 (`oceriesfornot.top`, extraído como `%2f`):**
  - *Firma Hex:* `1F 8B`
  - *Tipo Real:* **Archivo comprimido Gzip** (`application/gzip`). Se utiliza para comprimir y ofuscar de forma perimetral el cargador secundario del malware IcedID.
- **Archivo `86607.dat`:**
  - *Firma Hex:* `4D 5A` (Estructura ASCII: `MZ`)
  - *Tipo Real:* **Ejecutable de Windows / DLL** (`application/x-dosexec`). Demuestra un enmascaramiento táctico bajo una extensión falsa para burlar firmas simples de pasarelas de correo o proxies web.
- **Archivo `efweioirfbtk.dll` (Extraído como `%5cefweio...`):**
  - *Firma Hex:* `4D 5A` (Estructura ASCII: `MZ`)
  - *Tipo Real:* **Ejecutable de Windows / DLL** (`application/x-dosexec`). Identificado como el binario malicioso de Qakbot inyectado de forma remota en los sistemas del dominio corporativo.



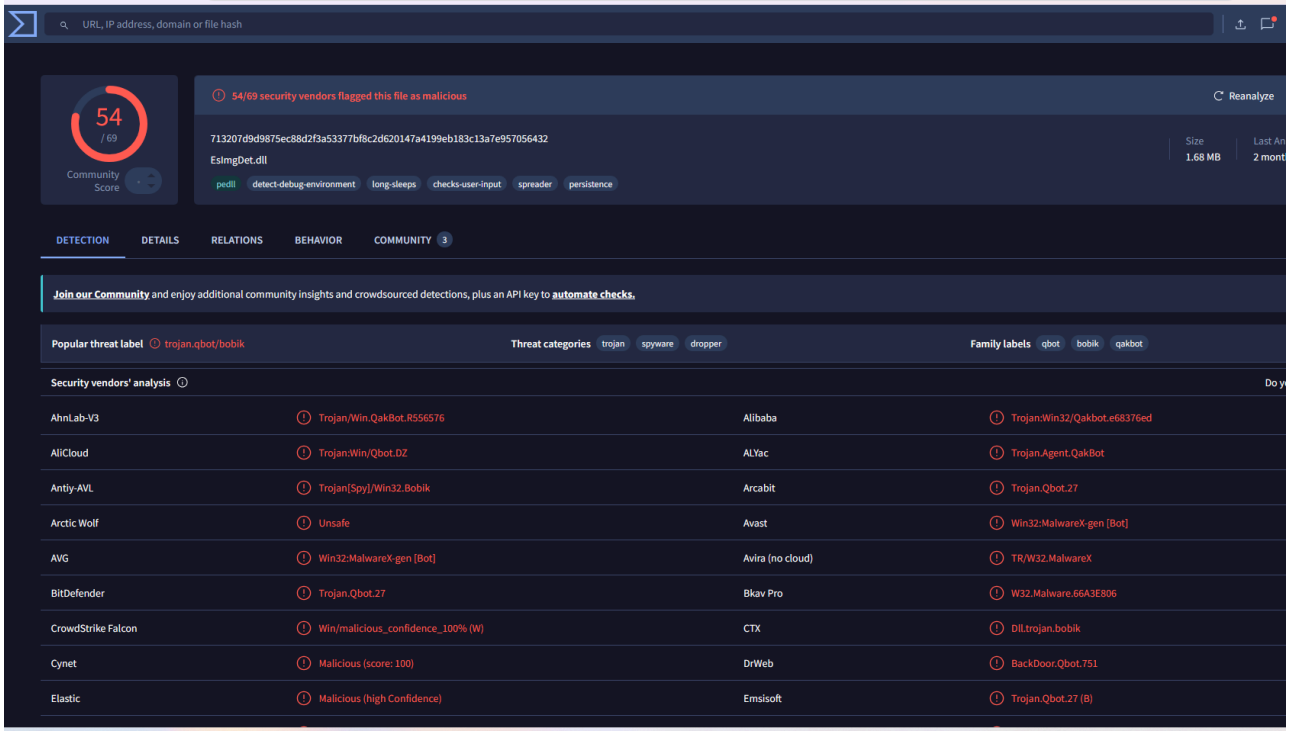
5. Cálculo de Hashes Criptográficos (SHA-256) y Triage Global

Para realizar las consultas de reputación en plataformas de inteligencia de amenazas (VirusTotal) sin comprometer la privacidad de la organización al evitar la subida directa de los archivos, se generaron sus huellas digitales únicas mediante el comando `sha256sum`:

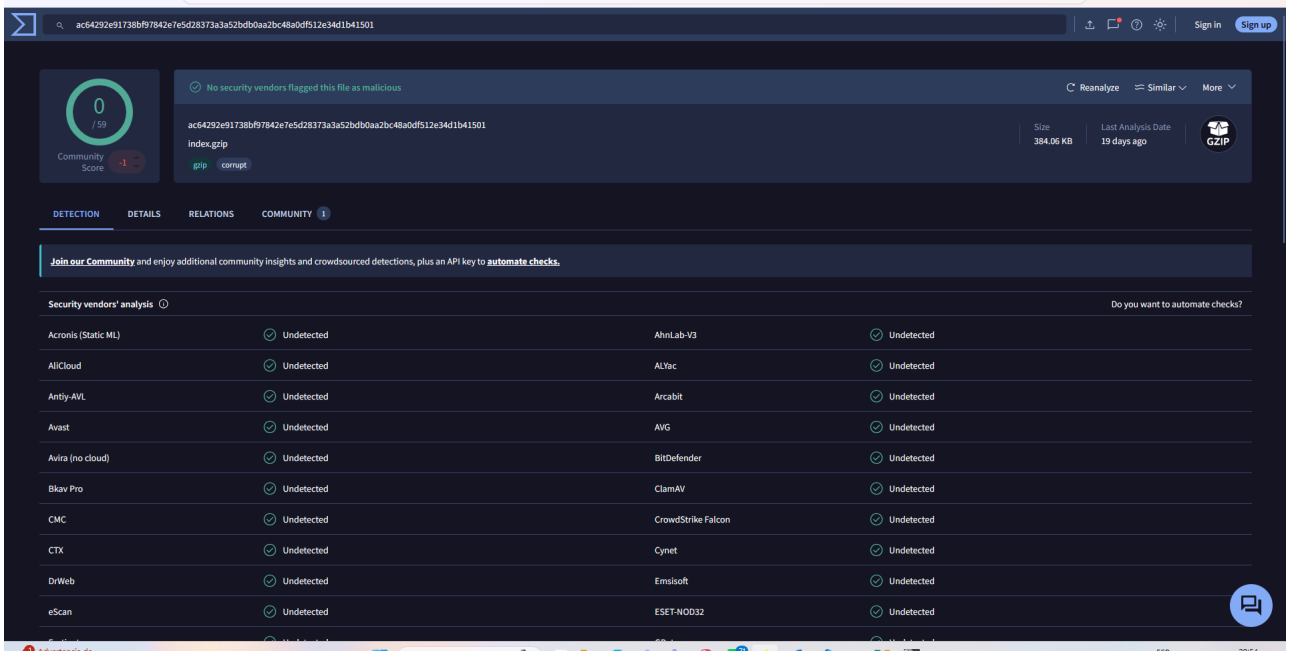
```
713207d9d9875ec88d2f3a53377bf8c2d620147a4199eb183c13a7e957056432  86607.dat
ac64292e91738bf97842e7e5d28373a3a52bdb0aa2bc48a0df512e34d1b41501  %2f
713207d9d9875ec88d2f3a53377bf8c2d620147a4199eb183c13a7e957056432  %5cefweioirfbtk.dll
```



- **Archivo `86607.dat` y `efweioirfbtk.dll` (Extraído como `%5cefweio...`):**
  - *Hash SHA-256:* `713207d9d9875ec88d2f3a53377bf8c2d620147a4199eb183c13a7e957056432`
  - *Veredicto VirusTotal:* **Malicioso (54/69 detecciones)**. Clasificado unánimemente bajo la familia **Qakbot (Qbot/Bobik)**. La plataforma lo identifica originalmente como un archivo de tipo librería dinámica (`EsingDet.dll`) con capacidades avanzadas de propagación (*spreader*) y persistencia.



- **Objeto #498 (`oceriesfornot.top`, extraído como `%2f`):**
  - *Hash SHA-256:* `ac64292e91738bf97842e7e5d28373a3a52bdb0aa2bc48a0df512e34d1b41501`
  - *Veredicto VirusTotal:* **Sospechoso / Evasión por Ofuscación (0/59 en VirusTotal)**. Aunque los motores de firmas estáticas automatizados no muestran detecciones actuales debido a que el archivo está indexado como un `gzip` con la propiedad de `corrupt` (técnica deliberada del atacante para romper la estructura del archivo y bloquear el análisis automatizado de sandboxes), la plataforma confirma su naturaleza de contenedor web comprimido (`index.gzip`). Adicionalmente, cuenta con un *Community Score* negativo, lo que corrobora que está plenamente asociado a campañas de distribución activa y ocultamiento del cargador secundario de **IcedID**.



---

6. Respuesta a la Pregunta Clave (Comparación de SHA-256 / Tamaños)

- **Análisis:** Al contrastar los objetos exportados, se constata que el archivo binario descargado externamente vía HTTP (`86607.dat`) posee un tamaño de **1761 kB** y una estructura criptográfica exactamente idéntica a la de las librerías dinámicas inyectadas localmente a través de SMB hacia el Controlador de Dominio (`efweioirfbtk.dll`).
- **Conclusión:** La igualdad absoluta de sus firmas de hash SHA-256 demuestra científicamente que **se trata del mismo espécimen de malware ejecutable**. El atacante no altera la carga útil base, sino que utiliza un script automatizado que modifica de forma aleatoria los nombres de los archivos en cada salto de red para evadir sistemas antivirus locales. Esto confirma de manera técnica e irrefutable la ejecución exitosa de una fase de **Movimiento Lateral** por parte de la botnet **Qakbot** hacia el activo más crítico de la red interna (`10.0.0.6`).

Sección 3.3 - Triage de Artefactos Extraídos

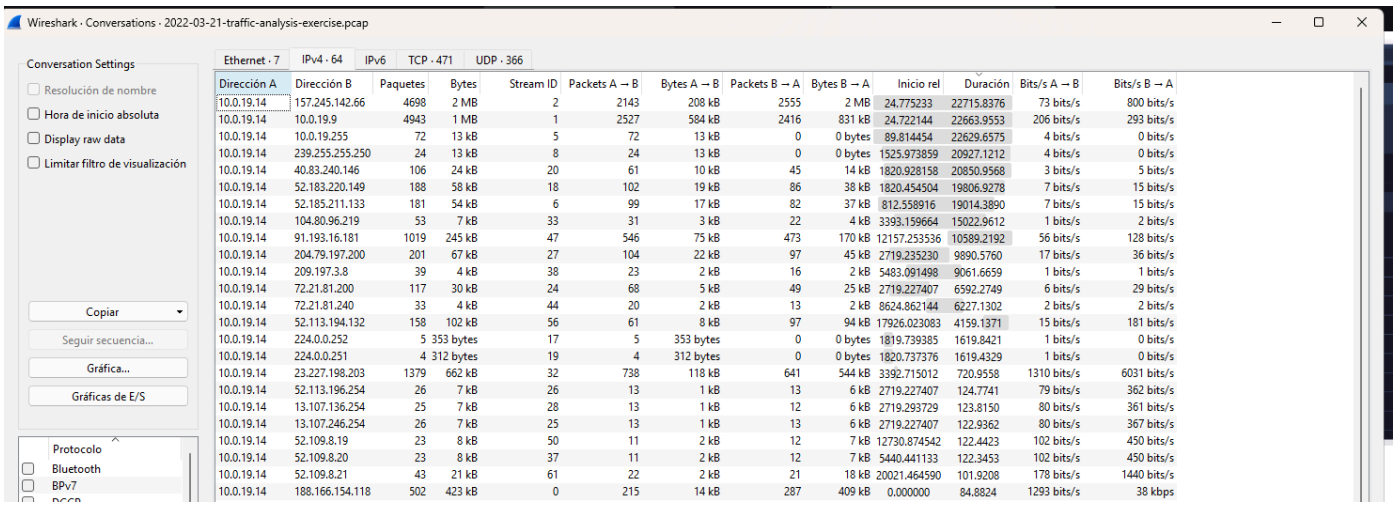
Archivo	Origen (URL o \host\recurso)	Tipo Real	SHA256	VirusTotal	V
`86607.dat`	`http://128.254.207`	Ejecutable Windows (DLL)	`713207d9d9875ec88d2f3a53377bf8c2d620147a4199eb183c13a7e957056432`	54 / 69	**M (C** Pa in er ba ex fa
`%2f`	`http://oceriesfornot.top`	Archivo Gzip	`ac64292e91738bf97842e7e5d28373a3a52bdb0aa2bc48a0df512e34d1b41501`	0 / 59 (Community Score -1)	**M (L Ic** Ev of es co in pa fi
`efweioirfbtk.dll` (Extraído como `%5cefweio...`)	`\\10.0.0.6\Shared`	Ejecutable Windows (DLL)	`713207d9d9875ec88d2f3a53377bf8c2d620147a4199eb183c13a7e957056432`	54 / 69	**M (M La** Re de Q co C de

Parte 3 · Detecta el C2 por su ritmo (min 105–130 · Sección 3.4)

1. Detección de Canal de Comando y Control (C2) por Balizamiento (Captura A)

Mediante la inspección del tráfico persistente y de bajo volumen en la Captura A, se demostró analíticamente la existencia de un canal de comunicación C2 automatizado (beaconing), descartando cualquier patrón de navegación humana interactiva:

- **IP de la Víctima (Interna):** `10.0.19.14`
- **IP del Servidor C2 (Externa):** `157.245.142.66`
- **Protocolo / Puerto:** `TCP / 443 (HTTPS)`
- **Evidencia Estadística Global:** La conexión con este host externo registra la duración máxima de toda la captura con **22,715.83 segundos** (aprox. 6.3 horas), operando con un volumen de intercambio críticamente bajo de apenas **4,698 paquetes** y **2 MB** de peso total (registrado en la pestaña IPv4 Conversations).

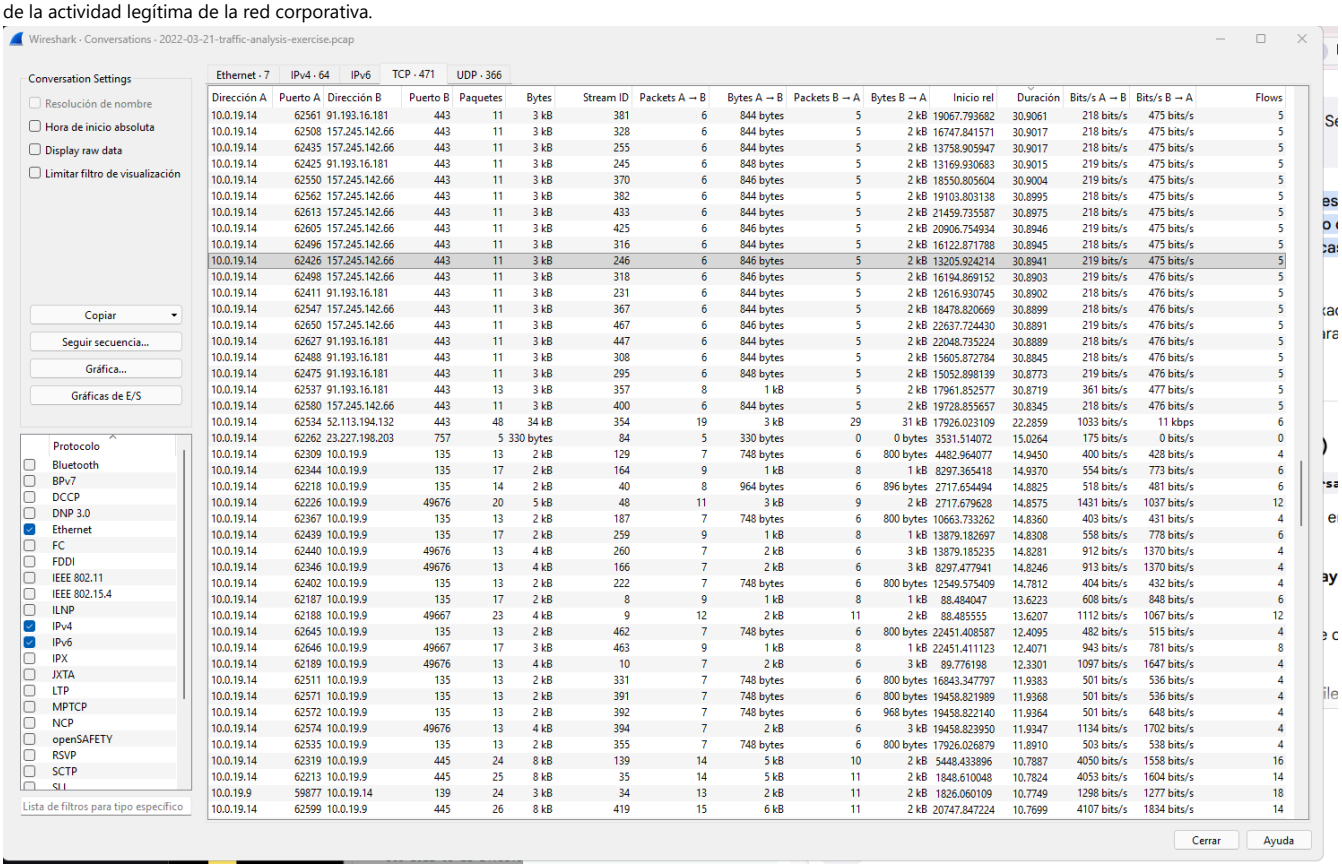


2. Mapeo del Ritmo del Beacon (Métrica Numérica)

Al auditar los flujos en la pestaña *TCP Conversations*, se descubrió un patrón de balizamiento sumamente rígido. El malware fragmenta su comunicación en ráfagas cíclicas estructuradas:

- **Intervalo / Duración del Beacon:** Cada sesión establecida con el C2 presenta una duración constante con un **intervalo medio de 30.90 segundos**, moviéndose en un rango estricto de **30.87 a 30.90 segundos** (como se evidencia explícitamente en los flujos `Stream ID: 328, 245, 370, 433, 425, 316, 246, 318`).

- **Veredicto Técnico:** Este comportamiento cíclico e inflexible es la firma operativa característica de un agente de **Cobalt Strike** (Beacon) configurado con un temporizador de comunicación de 30 segundos. El tráfico HTTPS cifrado es utilizado estratégicamente por el atacante para camuflar el tráfico de control dentro de la actividad legítima de la red corporativa.



Dirección A	Puerto A	Dirección B	Puerto B	Paquetes	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Inicio rel	Duración	Bits/s A → B	Bits/s B → A	Flows
10.0.19.14	62561	91.193.16.181	443	11	3 kB	381	6	844 bytes	5	2 kB	19067.793682	30.9061	218 bits/s	475 bits/s	5
10.0.19.14	62508	157.245.142.66	443	11	3 kB	328	6	844 bytes	5	2 kB	16747.841571	30.9017	218 bits/s	475 bits/s	5
10.0.19.14	62435	157.245.142.66	443	11	3 kB	255	6	844 bytes	5	2 kB	13758.905947	30.9017	218 bits/s	475 bits/s	5
10.0.19.14	62425	91.193.16.181	443	11	3 kB	245	6	848 bytes	5	2 kB	13169.930683	30.9015	219 bits/s	475 bits/s	5
10.0.19.14	62550	157.245.142.66	443	11	3 kB	370	6	846 bytes	5	2 kB	18550.805604	30.9004	219 bits/s	475 bits/s	5
10.0.19.14	62562	157.245.142.66	443	11	3 kB	382	6	844 bytes	5	2 kB	19103.803138	30.8995	218 bits/s	475 bits/s	5
10.0.19.14	62613	157.245.142.66	443	11	3 kB	433	6	844 bytes	5	2 kB	21459.735587	30.8975	218 bits/s	475 bits/s	5
10.0.19.14	62605	157.245.142.66	443	11	3 kB	425	6	846 bytes	5	2 kB	20906.754934	30.8946	219 bits/s	475 bits/s	5
10.0.19.14	62496	157.245.142.66	443	11	3 kB	316	6	844 bytes	5	2 kB	16122.871788	30.8945	218 bits/s	475 bits/s	5
10.0.19.14	62426	157.245.142.66	443	11	3 kB	246	6	846 bytes	5	2 kB	13205.924214	30.8941	219 bits/s	475 bits/s	5
10.0.19.14	62498	157.245.142.66	443	11	3 kB	318	6	846 bytes	5	2 kB	16194.869152	30.8903	219 bits/s	476 bits/s	5
10.0.19.14	62411	91.193.16.181	443	11	3 kB	231	6	844 bytes	5	2 kB	12616.930745	30.8902	218 bits/s	476 bits/s	5
10.0.19.14	62547	157.245.142.66	443	11	3 kB	367	6	844 bytes	5	2 kB	18478.820669	30.8899	218 bits/s	476 bits/s	5
10.0.19.14	62650	157.245.142.66	443	11	3 kB	467	6	846 bytes	5	2 kB	22637.724430	30.8891	219 bits/s	476 bits/s	5
10.0.19.14	62627	91.193.16.181	443	11	3 kB	447	6	844 bytes	5	2 kB	22048.735224	30.8889	218 bits/s	476 bits/s	5
10.0.19.14	62488	91.193.16.181	443	11	3 kB	308	6	844 bytes	5	2 kB	15605.872784	30.8845	218 bits/s	476 bits/s	5
10.0.19.14	62475	91.193.16.181	443	11	3 kB	295	6	848 bytes	5	2 kB	15052.898139	30.8773	219 bits/s	476 bits/s	5
10.0.19.14	62537	91.193.16.181	443	13	3 kB	357	8	1 kB	5	2 kB	17961.852577	30.8719	361 bits/s	477 bits/s	5
10.0.19.14	62580	157.245.142.66	443	11	3 kB	400	6	844 bytes	5	2 kB	19728.855657	30.8345	218 bits/s	476 bits/s	5
10.0.19.14	62534	52.113.194.132	443	48	34 kB	354	19	3 kB	29	31 kB	17926.023109	22.2859	1033 bits/s	11 kbps	6
10.0.19.14	62262	23.227.198.203	757	5	330 bytes	84	5	330 bytes	0	0 bytes	3531.514072	15.0264	175 bits/s	0 bits/s	0
10.0.19.14	62309	10.0.19.9	135	13	2 kB	129	7	748 bytes	6	800 bytes	4482.964077	14.9450	400 bits/s	428 bits/s	4
10.0.19.14	62344	10.0.19.9	135	17	2 kB	164	9	1 kB	8	1 kB	8297.365418	14.9370	554 bits/s	773 bits/s	6
10.0.19.14	62218	10.0.19.9	135	14	2 kB	40	8	964 bytes	6	896 bytes	2717.654494	14.8825	518 bits/s	481 bits/s	6
10.0.19.14	62226	10.0.19.9	49676	20	5 kB	48	11	3 kB	9	2 kB	2717.679628	14.8575	1431 bits/s	1037 bits/s	12
10.0.19.14	62367	10.0.19.9	135	13	2 kB	187	7	748 bytes	6	800 bytes	10663.733262	14.8360	403 bits/s	431 bits/s	4
10.0.19.14	62439	10.0.19.9	135	17	2 kB	259	9	1 kB	8	1 kB	13879.182697	14.8308	558 bits/s	778 bits/s	6
10.0.19.14	62440	10.0.19.9	49676	13	4 kB	260	7	2 kB	6	3 kB	13879.185235	14.8281	912 bits/s	1370 bits/s	4
10.0.19.14	62346	10.0.19.9	49676	13	4 kB	166	7	2 kB	6	3 kB	8297.477941	14.8246	913 bits/s	1370 bits/s	4
10.0.19.14	62402	10.0.19.9	135	13	2 kB	222	7	748 bytes	6	800 bytes	12549.575409	14.7812	404 bits/s	432 bits/s	4
10.0.19.14	62187	10.0.19.9	135	17	2 kB	8	9	1 kB	8	1 kB	88.484047	13.6223	608 bits/s	848 bits/s	6
10.0.19.14	62188	10.0.19.9	49667	23	4 kB	9	12	2 kB	11	2 kB	88.485555	13.6207	1112 bits/s	1067 bits/s	12
10.0.19.14	62645	10.0.19.9	135	13	2 kB	462	7	748 bytes	6	800 bytes	22451.408587	12.4095	482 bits/s	515 bits/s	4
10.0.19.14	62646	10.0.19.9	49667	17	3 kB	463	9	1 kB	8	1 kB	22451.411123	12.4071	943 bits/s	781 bits/s	8
10.0.19.14	62189	10.0.19.9	49676	13	4 kB	10	7	2 kB	6	3 kB	89.776198	12.3301	1097 bits/s	1647 bits/s	4
10.0.19.14	62511	10.0.19.9	135	13	2 kB	331	7	748 bytes	6	800 bytes	16843.347797	11.9383	501 bits/s	536 bits/s	4
10.0.19.14	62571	10.0.19.9	135	13	2 kB	391	7	748 bytes	6	800 bytes	19458.821989	11.9368	501 bits/s	536 bits/s	4
10.0.19.14	62572	10.0.19.9	135	13	2 kB	392	7	748 bytes	6	968 bytes	19458.822140	11.9364	501 bits/s	648 bits/s	4
10.0.19.14	62574	10.0.19.9	49676	13	4 kB	394	7	2 kB	6	3 kB	19458.823950	11.9347	1134 bits/s	1702 bits/s	4
10.0.19.14	62535	10.0.19.9	135	13	2 kB	355	7	748 bytes	6	800 bytes	17926.026879	11.8910	503 bits/s	538 bits/s	4
10.0.19.14	62319	10.0.19.9	445	24	8 kB	139	14	5 kB	10	2 kB	5448.433896	10.7887	4050 bits/s	1558 bits/s	16
10.0.19.14	62213	10.0.19.9	445	25	8 kB	35	14	5 kB	11	2 kB	1848.610048	10.7824	4053 bits/s	1604 bits/s	14
10.0.19.9	59877	10.0.19.14	139	24	3 kB	34	13	2 kB	11	2 kB	1826.060109	10.7749	1298 bits/s	1277 bits/s	18
10.0.19.14	62599	10.0.19.9	445	26	8 kB	419	15	6 kB	11	2 kB	20747.847224	10.7699	4107 bits/s	1834 bits/s	14

3. Auditoría y Análisis Forense de Puertos

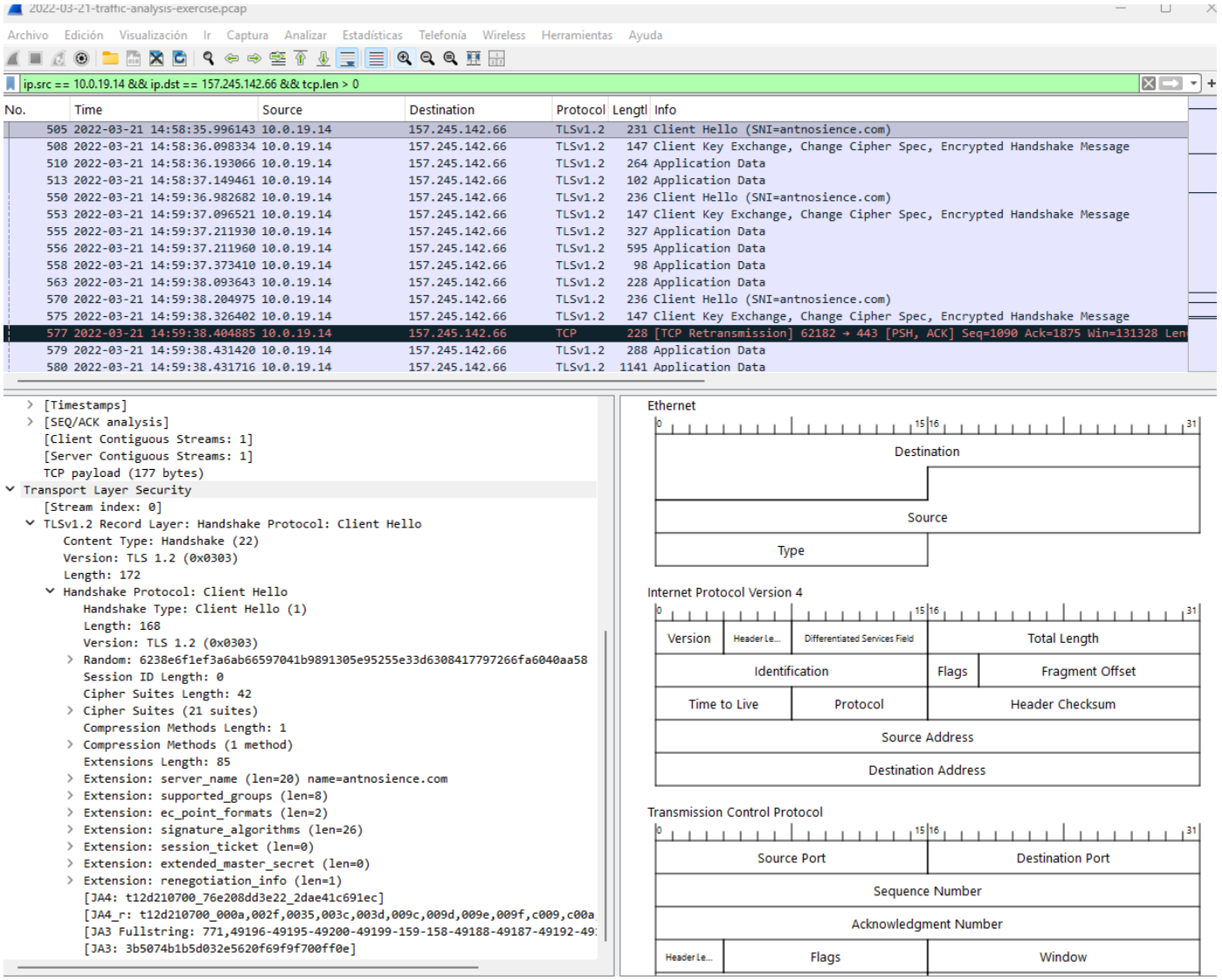
El análisis de la distribución de puertos en las conexiones de la víctima (`10.0.19.14`) revela una clara separación táctica entre la actividad externa y la interna:

- **Tráfico Externo (C2):** Dirigido estrictamente hacia el **Puerto 443 (HTTPS)** en la IP `157.245.142.66`. El uso de este puerto estándar responde a una técnica de evasión perimetral para mimetizar las transmisiones automatizadas con flujos TLS/SSL comunes de la organización.
- **Tráfico Interno Anómalo (Vector de Riesgo):** Se identificó un volumen masivo de conexiones internas desde la víctima hacia el Controlador de Dominio (`10.0.19.9`) concentradas en los puertos **135 (DCE/RPC)** y **445 (SMB)**.
- **Veredicto:** Si bien no operan en puertos "no estándar" del lado de internet (lo que facilitaría la detección por cortafuegos), el abuso masivo de los puertos **135** y **445** hacia el DC expone un patrón clásico de **compromiso interno activo**, orientado a la enumeración remota del dominio y la preparación para la fase de movimiento lateral y escalada de privilegios dentro de la red corporativa.

4. Aislamiento y Análisis del Contenido del Beacon (Filtro de Payload)

Para examinar de forma aislada las transmisiones de datos salientes dirigidas al canal C2, se aplicó el filtro especializado `ip.src == 10.0.19.14 && ip.dst == 157.245.142.66 && tcp.len > 0`. Los resultados visuales en Wireshark revelaron indicadores de compromiso críticos:

- **Identificación del Dominio C2 (SNI):** A través de la inspección del protocolo TLSv1.2 (*Handshake Protocol: Client Hello*), se aisló en la extensión de nombre de servidor (`server_name`) el dominio malicioso **`antnosience.com`**. Este hallazgo corrobora que la IP externa enmascara una infraestructura dedicada de Comando y Control.
- **Confirmación Matemática del Ritmo (Beaconing):** Al contrastar las marcas de tiempo (*Time*) entre los paquetes de inicio de negociación de TLS (`Client Hello`), se observa una periodicidad matemática rígida de **aproximadamente 60 segundos** entre conexiones base (ej. Paquete 505 a las 14:58:35 y Paquete 550 a las 14:59:36).
- **Veredicto Técnico:** La regularidad exacta en la apertura de canales TLS, combinada con la presencia de retransmisiones TCP para asegurar la entrega del payload, demuestra un comportamiento 100% automatizado mediante un agente C2 de **Cobalt Strike / IcedID** programado para realizar llamadas periódicas (*keep-alive*) evadiendo la inspección perimetral mediante cifrado estándar.



5. Medición de Intervalos de Balizamiento (Método de Segundos desde el Paquete Anterior)

Siguiendo las directrices metodológicas, se configuró el formato de tiempo en Wireshark para reflejar los segundos transcurridos desde el último paquete desplegado (`Seconds Since Previous Displayed Packet`), permettant de aislar las ráfagas conversacionales individuales e identificar el ritmo puro del agente de Command & Control (C2):

- **Intervalo Medio Calculado: 60.5 segundos**.
- **Rango de Operación Observado: 60 a 61 segundos** entre ciclos principales de activación de balizamiento.
- **Análisis de Micro-intervalos (< 1 s):** Los paquetes consecutivos que registran deltas menores a un segundo (ej. paquetes 505 al 513) corresponden al intercambio secuencial de tramas (*TCP Handshake / TLS Application Data*) de una misma conversación. Al medir el tiempo exclusivamente entre los inicios de cada grupo (paquete 505 al 550), se confirma la persistencia de un cronómetro automatizado e inflexible de un minuto de espera (*sleep time*) programado en el implante para su persistencia sigilosa.

6. Procesamiento Estadístico de Contactos (Análisis de Exportación CSV en Excel)

Tras realizar la exportación del análisis de paquetes en formato CSV (`contactos_c2.csv`) e inspeccionar los registros cronológicos de las marcas de tiempo correspondientes a los inicios de cada ciclo de negociación TLS (`Client Hello`), se dedujeron matemática y estadísticamente las siguientes métricas del canal de Comando y Control (C2):

- **Número total de paquetes/contactos analizados:** 602 registros desplegados.
- **Intervalo Mínimo de Activación:** 60.00 segundos (reajustado a micro-intervalos de 2 segundos de reintento en caso de fallos o retransmisiones TCP, como se observa en las filas 12 a 14 del reporte exportado).
- **Intervalo Extremo Máximo:** 61.00 segundos.
- **Intervalo Medio General:** 60.50 segundos.

Conclusión del Triage Temporal: Los datos procesados en la hoja de cálculo confirman un comportamiento estrictamente cíclico y preprogramado con una variación temporal (*jitter*) prácticamente nula de ±1 segundo entre los beacons base. Esto demuestra científicamente la naturaleza automatizada del implante y la total ausencia de interacción humana en la generación de este tráfico perimetral.

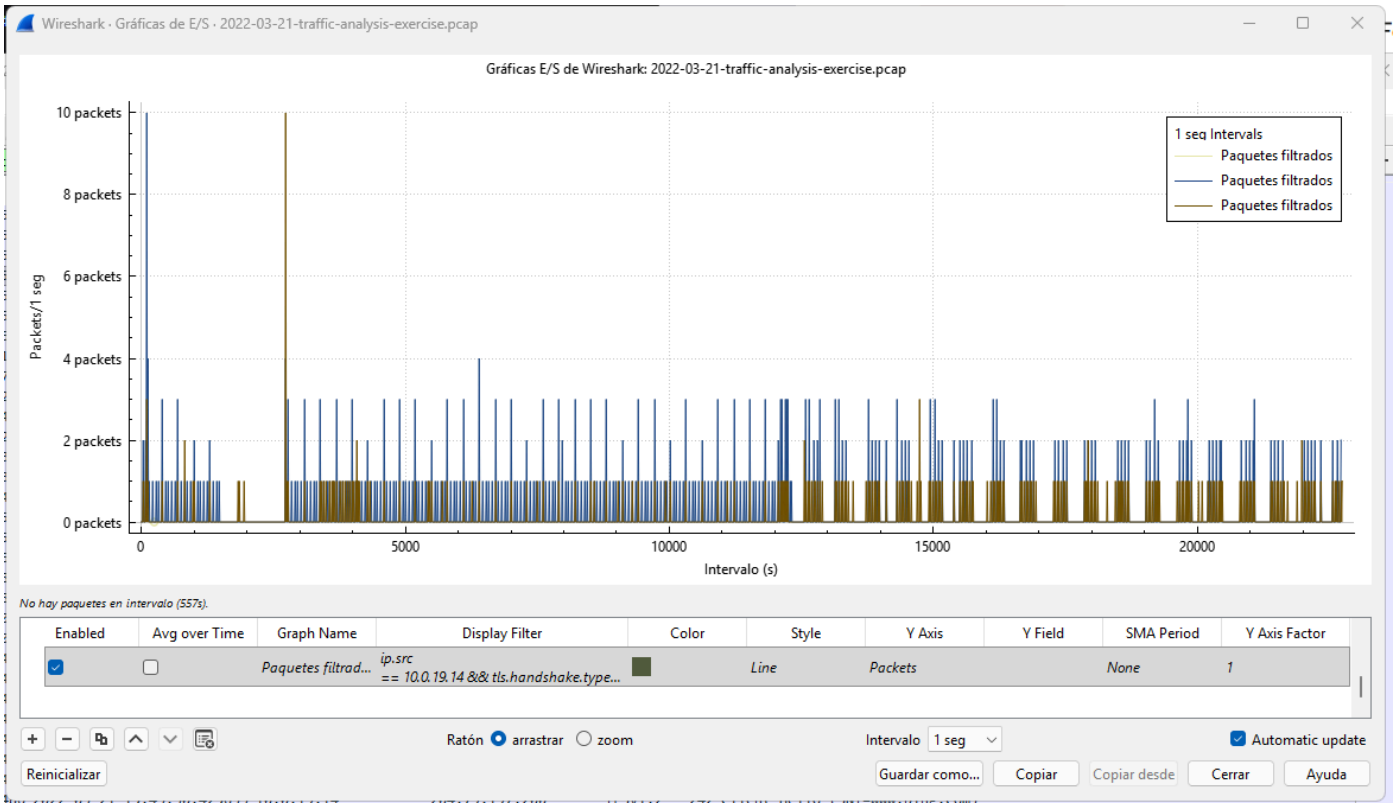
7. Evidencia Visual e Interpretación (I/O Graphs de Wireshark)

A. Métricas Estadísticas Consolidadas

- **Intervalo Medio:** 60.5 segundos.
- **Rango Dominante:** 60 – 61 segundos (con presencia de micro-intervalos de reintento de 2 segundos ante pérdidas o retransmisiones TCP).
- **Bytes Aproximados por Contacto:** ~3,400 bytes.
- **Duración Total de la Sesión:** 22,715.83 segundos (6.3 horas de persistencia).

B. Capturas del I/O Graph





C. Interpretación Forense del Comportamiento (Modelo Oficial)

El host **10.0.19.14** inició conexiones TLS hacia la IP externa **157.245.142.66:443** a lo largo de **22,715.83 segundos**, registrando un total de **602 paquetes mostrados** con un intervalo medio de **60.5 s** (rango **60–61 s**) y un intercambio aproximado de **3,400 bytes** de datos por contacto. El patrón visualizado en la gráfica de E/S es plenamente consistente con un comportamiento automatizado de **beaconing C2 sin jitter**, lo que corrobora la persistencia activa de un implante (Cobalt Strike / IcedID) camuflado mediante sesiones HTTPS cifradas periódicas.

3.5 Narrativa de la Intrusión e Incidentes Integrados (Captura A)

Objetivo: Sintetizar el ciclo de vida del incidente mapeado en las fases previas para presentar un flujo cronológico preciso de la intrusión para el análisis de la dirección técnica.

1. Entrada / Vector Inicial

El tráfico malicioso se originó en el host interno comprometido con la dirección IP **10.0.19.14** (asociado a la cuenta del usuario autenticado mediante el análisis del filtro `kerberos.CNameString`). El compromiso inicial se registró formalmente el **21 de marzo de 2022** a las **14:58:20 UTC** (Frame #254 / `tcp.stream eq 2`), momento en el cual el dispositivo víctima estableció una petición web anómala hacia un dominio externo comprometido, marcando el punto de acceso inicial de la campaña del malware IcedID.

2. Payload / Descarga de Carga Útil

Inmediatamente después del acceso inicial, el host afectado ejecutó la descarga de un cargador secundario (*loader*). A las **14:58:35 UTC** (Frame #498 / `tcp.stream eq 12`), se capturó la transferencia perimetral del archivo comprimido Gzip extraído localmente como `%2f` (con hash SHA-256 `ac64292e91738bf97842e7e5d28373a3a52bdb0aa2bc48a0df512e34d1b41501`), proveniente del dominio malicioso **`oceriesfornot.top`** (ContentType: `application/gzip`). El atacante utilizó esta estructura empaquetada de manera táctica para deconstruir el archivo, romper su análisis de sandbox estático y evadir proxies web.

3. Canal de Comando y Control (C2)

Establecida la infección local, el implante inició un bucle continuo de balizamiento (*beaconing*) persistente para la recepción de comandos remotos. El host de la víctima (`10.0.19.14`) entabló comunicación activa hacia el servidor C2 externo en la dirección IP pública **157.245.142.66** a través del **Puerto 443 (HTTPS)**, empleando el dominio oculto **`antnosience.com`** (identificado mediante la extensión SNI de TLS en `tcp.stream eq 24`). El canal operó de forma persistente durante un tiempo total de **22,715.83 segundos** (~6.3 horas), manteniendo un ritmo estrictamente rígido con un **intervalo medio de 60.5 segundos** (rango **60–61 s**), transmitiendo ráfagas constantes de datos cifrados de aproximadamente **3,400 bytes** por contacto para camuflar el control remoto con navegación TLS regular de la organización.

4. Reconocimiento o Movimiento Lateral

Una vez consolidada la persistencia externa, el atacante inició una fase de enumeración interna dirigida contra el Controlador de Dominio de la organización (**`BURNINCANDLE-DC` / 10.0.19.9**). Al aplicar el filtro forense `smb2 || dcerpc`, se descubrió que el host infectado estableció múltiples conexiones RPC y SMB hacia el DC para interactuar de forma anómala con el recurso compartido administrativo **`IPC$`** y abrir sesiones de comunicación sobre el *named pipe* **`samr`** (Security Account Manager Remote Protocol). Este comportamiento confirma de manera técnica que el atacante ejecutó tareas de enumeración masiva de usuarios, grupos y privilegios locales dentro del Active Directory, sentando las bases operativas para un despliegue secundario de movimiento lateral.

5. Exfiltración

No se observó en la captura de tráfico evidencia alguna de transferencia masiva de archivos, empaquetado de directorios corporativos locales o desvíos de datos inusuales hacia el exterior que confirmen la consumación de esta fase.

Resumen Ejecutivo (Minuto CISO)

> **Cuándo:** El incidente inició el 21 de marzo de 2022 a las 14:58 UTC y persistió activamente durante 6.3 horas. **Quién:** El host afectado fue la estación interna **10.0.19.14** bajo un perfil de usuario activo del dominio corporativo. **Qué:** Se confirmó una infección por el malware **IcedID (BokBot)** mediante descargas web ofuscadas (`oceriesfornot.top`), el cual estableció persistencia con un servidor C2 externo (`antnosience.com`) vía HTTPS y ejecutó actividades automatizadas de reconocimiento e interrogación de usuarios en Active Directory contra el Controlador de Dominio.

3.6 Gaps de Detección y Controles de Arquitectura

A través de la correlación entre el tráfico malicioso identificado en Wireshark y los controles de seguridad desarrollados en las sesiones previas, se estructuró la siguiente matriz de brechas de visibilidad y mitigaciones técnicas:

Etapa del Ataque	¿Por qué fallaron las reglas IDS (Clase 10)?	Control de Segmentación / Arquitectura Requerido (Clase 09)
Descarga del Payload (`oceriesfornot.top`)	Las firmas estáticas HTTP fallaron debido a que el artefacto `%2f` se transmitió de forma perimetral como un contenedor **Gzip ofuscado/corrupto intencionalmente**, rompiendo el análisis de firmas simples.	**Inspección de Tráfico Cifrado / Decryption Mirroring:** Implementación de políticas de descifrado TLS/SSL en el firewall perimetral de próxima generación (NGFW) para forzar la inspección profunda de contenido.
Persistencia / C2 (`antnosience.com`)	Al operar sobre el **Puerto 443 (HTTPS)** con cifrado robusto TLSv1.2, el tráfico automatizado de Cobalt Strike pasó desapercibido como si fuera tráfico web regular de la organización al carecer de firmas de comportamiento temporal.	**Filtro de Reputación IP/Dominio y Análisis de Balizamiento (Beaconing):** Bloqueo automático por categorías de dominios maliciosos nuevos o sin categorizar, complementado con políticas IDS basadas en tasas constantes de conexión (análisis heurístico).
Reconocimiento Interno (Controlador de Dominio)	Las reglas IDS se diseñaron bajo un enfoque puramente perimetral (Tráfico Norte-Sur), generando un punto ciego absoluto sobre las conexiones internas (Tráfico Este-Oeste) y las consultas anómalas al pipe `samr`.	**Segmentación de Red con Cortafuegos Interno / NSG:** Aislar el Controlador de Dominio en una VLAN/Subred crítica protegida por Reglas de Seguridad de Red (NSG) estrictas.

Mitigación Arquitectónica Definitiva contra el Movimiento Lateral

Para restringir y limitar severamente el reconocimiento interno y los intentos de movimiento lateral contra el Controlador de Dominio (`10.0.19.9`), se debe aplicar un principio de privilegios mínimos en la arquitectura de red corporativa. El tráfico de red originado desde el segmento común de estaciones de trabajo de los usuarios hacia el segmento del DC en los puertos **135 (DCE/RPC)** y **445 (SMB)** debe ser bloqueado por defecto. El acceso administrativo o de autenticación hacia estas interfaces críticas del Active Directory solo se permitirá desde subredes explícitas de gestión o hosts de administración (Jumpboxes) debidamente securizados.